Антикризисный гайд защиты кейса ВТБ: Ответы на каверзные вопросы жюри (Q&A Defense Guide)

> **Шпаргалка для команды перед защитой:** 12 самых сложных и агрессивных вопросов от экспертов ИБ, юристов, рисковиков и продуктового блока с эталонными ответами.
> **Чемпионат:** Changellenge >> Cup Moscow 2026 (Банк ВТБ)

БЛОК 1. Архитектура и разграничение 161-ФЗ (Вопросы 1–3)

Вопрос 1: В чем фундаментальная причина сбоев существующей антифрод-системы ВТБ и почему честные клиенты страдают от ложных блокировок?

- **Эталонный ответ:**
  «Фундаментальная причина — **бинарность логики принятия решений**. Текущая модель антифрода знает только два состояния: либо *пропустить операцию*, либо *наглухо заблокировать ДБО на 48 часов* и отправить клиента в отделение с паспортом. Система ошибочно ставит знак равенства между *подозрением внутреннего ML-алгоритма* (например, смена SIM-карты накануне у добросовестного Никиты) и *черным списком мошенников Банка России*. В результате на 1 реальную атаку банк останавливает 12 честных клиентов (соотношение FP к TP = 11,8 к 1), что обваливает лояльность до NPS = -40 и генерирует банку более 168 млн рублей ежегодных операционных затрат на очереди в офисах».

Вопрос 2: Как именно ваше решение уходит от этой бинарности, что происходит с клиентом вместо блокировки и почему это законно по 161-ФЗ?

- **Эталонный ответ:**
  «Мы разделяем весь поток операций на два строгих регуляторных контура:
  1. **Императивный стоп-контур (ч. 3.6 ст. 8 закона № 161-ФЗ):** Если реквизит получателя уже есть в государственной базе данных Банка России (ФинЦЕРТ), действует обязательный 48-часовой блок без исключений, иначе банк понесет 100% финансовую ответственность по правилу 30 дней.
  2. **Оценочный контур банка (Серая зона ML):** Если получателя в базе ЦБ нет, но скоринг сработал на нетипичное поведение клиента (кейс Никиты у кассы), мы опираемся на **ч. 3.8 ст. 8 закона № 161-ФЗ**, которая *прямо обязывает банк уведомить клиента о приостановлении и предоставить ему возможность подтвердить распоряжение электронным путем*. Вместо блокировки мы запускаем **15-секундный In-Flow Liveness Step-Up (видеоселфи)** в приложении. Никита подтверждает лицо за 15 секунд прямо у кассы, сделка проходит, а банк экономит 750 рублей на визите в офис».

Вопрос 3: Пенсионерку «ведет» мошенник под видом майора ФСБ и приказывает перевести 1,5 млн рублей. Или мошенники используют дипфейк/трансляцию экрана. Как ваша система поймет, что селфи пропускать нельзя?

- **Эталонный ответ (4 эшелона защиты):**
  «Система нейтрализует этот сценарий на 4 независимых уровнях, где Liveness — лишь один из рубежей:
  1. **Защита самого Liveness SDK от дипфейков и трансляций экранов:**
     - *Screen Flash Reflection:* В момент съемки экран смартфона на доли секунды меняет цвет и яркость вспышки, анализируя отражение световых бликов на роговице глаза и коже. Статичное фото, видеопоток или дипфейк с монитора физически не способны дать синхронный световой отклик.
     - *Аппаратные сенсоры:* SDK считывает данные гироскопа и акселерометра (естественный микротремор руки человека). Если телефон неподвижно закреплен перед другим экраном — проверка бракуется.
     - *Secure Camera Stream:* Прямой опрос камеры без возможности подмены потока через виртуальные камеры или эмуляторы.
  2. **Детекция активного звонка (Признак ОБДС № 9):**
     - Если пенсионерка в момент перевода «висит на трубке» с "майором", наш Mobile SDK (Call State API) и телеком-шлюз фиксируют активный вызов. При активном разговоре **Liveness Step-Up блокируется**, а на экран выводится жесткая интервенция: *«Вы разговариваете по телефону. Немедленно положите трубку — это мошенники!»*.
  3. **Детекция AnyDesk / удаленного доступа (Признак ОБДС № 10):**
     - Служба Accessibility Services Watcher на Android видит факт удаленного управления экраном. При активной сессии удаленного доступа быстрый путь мгновенно закрывается.
  4. **Tier 2 («ВТБ Сейф») — физическая невозможность кражи накоплений:**
     - 1,5 млн рублей пенсионерки лежат не на дебетовой карте, а в «Сейфе». Со счета Сейфа **в принципе нельзя сделать моментальный перевод по СБП**. Запускается 24-часовой Time-Lock. Даже если бы она прошла селфи, деньги поступят на карту только через сутки, а мошенники не могут держать жертву в трансе 24 часа.
  5. **Tier 3 («Защита близких Pro»):**
     - Сыну пенсионерки мгновенно прилетает тревожный Push: *«Марии Ивановне прямо сейчас звонят во время финансовой операции!»*. Сын перезванивает и срывает атаку».

БЛОК 2. Юридическая чистота и законодательство РФ (Вопросы 4–6)

Вопрос 4: Клиент добровольно запер деньги в «ВТБ Сейфе», но у него произошло реальное ЧП (авария, срочная операция), и деньги нужны сиюминутно. Не нарушает ли 24-часовой таймлок ст. 858 ГК РФ («Ограничение распоряжения счетом»)?

- **Эталонный ответ:**
  «Нет, закон не нарушается по двум фундаментальным причинам:
  1. **Принцип свободы договора (ст. 421 ГК РФ):** Банк не ограничивает счет в одностороннем порядке. Клиент **сам добровольно (Opt-in)** подключает режим повышенной защиты для сберегательного

счета и акцептует регламент вывода. Это полный юридический аналог срочных вкладов (ст. 837 ГК РФ) или режима T+1/T+2 на брокерских счетах.

2. **Наличие безусловного Fail-Safe контура:** 24-часовой таймлок действует **только на дистанционные каналы (ДБО)**, где есть риск телефонного мошенничества. Если у клиента реальное ЧП, он лично обращается в **любое отделение ВТБ с паспортом**. Личное присутствие исключает дистанционную социнженерию, и деньги выдаются через кассу **мгновенно без каких-либо задержек**. Кроме того, текущие операционные средства на дебетовой карте (Hot Wallet) никогда не замораживаются и доступны 24/7».

Вопрос 5: Как ваше решение согласуется с новым законом о самозапрете на кредиты (31-ФЗ)? Зачем нужен ваш «Кредитный замок», если есть Госуслуги?

- **Эталонный ответ:**
  «Мы не дублируем, а усиливаем 31-ФЗ, закрывая его главное ограничение:
  - **31-ФЗ через Госуслуги** — это *тотальный и жесткий запрет*: чтобы его снять, клиенту нужно подать заявление и ждать **2 календарных дня** (период охлаждения). Для финансово активных людей это неудобно.
  - **«Кредитный замок» ВТБ (Tier 3)** — это *гибкий семейный контур (Second-Party Consent)*: клиент может брать кредиты в ВТБ, но каждая онлайн-заявка требует подтверждения от доверенного лица (супруги, сына) через Push за 1 минуту.
  - Кроме того, в нашем решении внедрена прямая кнопка передачи заявления на Госуслуги прямо из мобильного банка, что повышает комплаенс ВТБ».

Вопрос 6: Верховный Суд РФ все чаще признает кредиты, взятые мошенниками, недействительными. Как ваше решение защищает банк от судебных убытков?

- **Эталонный ответ:**
  «Наше решение прямо опирается на **Определения Верховного Суда РФ № 5-КГ23-146-К2 и № 5-КГ23-82-К2**. ВС РФ указал: *банк обязан проявлять повышенную осмотрительность при нетипичном онлайн-кредитовании, иначе договор признается ничтожным из-за порока воли*. Внедрив "Кредитный замок" (Second-Party Consent) и проверку активного вызова во время оформления кредита, ВТБ юридически доказывает в суде максимальную добросовестность и осмотрительность, полностью исключая риск аннулирования кредитных договоров».

БЛОК 3. Экономика, сметы и Unit-затраты (Вопросы 7–9)

Вопрос 7: Откуда взята цифра себестоимости одного очного визита в отделение в 750 рублей и ставка часа 2 200 рублей?

- **Эталонный ответ:**
  «Это расчет по методологии **Activity-Based Costing (ABC)** для розничной сети топ-3 банков РФ:

1. *Содержание одного рабочего места операциониста в месяц:* ФОТ с премией (90k) + страховые взносы 30,2% (27k) + аренда 10 кв.м street-retail с коммунальными услугами и охраной (50k) + IT-лицензии CRM/АБС и техника (15k) + общебанковские накладные (18k) = **~200 000 рублей в месяц**.
2. *Фонд полезного времени (Customer-Facing Time):* По нормативам систем управления очередью (Qmatic) и теории Erlang C, коэффициент продуктивной утилизации операциониста составляет **~55%** (остальные 45% — открытие/закрытие опердня, кассовые сверки, планерки, перерывы СанПиН). Из 168 рабочих часов чистое время приема клиентов составляет **~91 час в месяц**.
3. *Стоимость 1 часа приема:* $200,000 / 91 \approx \mathbf{2,200\text{ руб./час}}$ (или 36,7 руб./мин).
4. *Визит при ложной блокировке:* Разбор инцидента, проверка паспорта, снятие компрометации в CRM и заявление занимают **20 минут**. $20\text{ мин} \times 36,7\text{ руб.} = \mathbf{734–750\text{ рублей}}$. Это подтверждается отраслевыми бенчмарками McKinsey и BCG (600–900 ₽ за визит)».

Вопрос 8: Смета ровно 50,0 млн рублей — выглядит «подогнанной» под лимит кейса. Как вы докажете реальность этой сметы?

- **Эталонный ответ:**
  «Смета рассчитана "снизу вверх" (Bottom-Up) по стандартам финтех-разработки в Москве:
  - **Рыночная ставка Senior/Lead инженера:** 350k net $\implies$ 380k gross $\implies$ с налогами 30,2% и накладными оверхедами = **500 тыс. руб./человеко-месяц** (данные Хабр Карьеры и HeadHunter).
  - **Трудозатраты выделенной команды из 22 специалистов на 86 человеко-месяцев = 43,0 млн рублей:**
    - Liveness SDK (28 чел.-мес.) = 14,0 млн ₽;
    - Core Banking Сейф (18 чел.-мес.) = 9,0 млн ₽;
    - Оркестратор решений на Go (24 чел.-мес.) = 12,0 млн ₽;
    - Семейный контур и 31-ФЗ (16 чел.-мес.) = 8,0 млн ₽.
  - **Инфраструктура и аудит ИБ = 7,0 млн рублей:**
    - Закупка 4 GPU-серверов инференса (NVIDIA L4) = 2,5 млн ₽;
    - Внешний пентест и аудит (BI.ZONE / Positive Technologies) = 1,8 млн ₽;
    - Сертификация соответствия ГОСТ Р 57580.1 / Положение 683-П = 1,2 млн ₽;
    - Резерв Contingency (10%) = 1,5 млн ₽. Сумма: $43,0 + 7,0 = \mathbf{50,0\text{ млн рублей}}$».

Вопрос 9: Вы заложили, что платную подписку Tier 4 за 149 ₽/мес купят 500 тыс. человек. Не слишком ли это оптимистично?

- **Эталонный ответ:**
  «Оценка ультраконсервативна:
  1. *Проникновение:* 500 тыс. человек — это всего **1,65% от всей 30,3-миллионной базы ВТБ** (или 2,27% от активной базы ДБО). Для сравнения: проникновение Tinkoff Pro превышает 10%, подписки Сбера — более 8%.
  2. *Уникальное УТП:* На рынке нет ни одной розничной страховки, которая возмещает ущерб от *социальной инженерии*. Все страховки отказывают, если клиент сам нажал кнопку. Мы даем реальное

покрытие до 1 млн рублей плюс консьержа SOS за 10 секунд.

3. **Стресс-тест на безубыточность (Break-even):** Даже если платную подписку **не купит вообще никто (0 человек)**, проект окупается за 1 год только на экономии издержек от снижения ложных блокировок (достаточно сократить FP всего на 13,8% при нашем потенциале 65–70%)».

БЛОК 4. Технологическая реализуемость и сроки (Вопросы 10–12)

Вопрос 10: Ядро банка (Core Banking / АБС) — неповоротливая легаси-система. Как вы собираетесь внедрить механику «ВТБ Сейф» всего за 2,5 месяца?

- **Эталонный ответ:**
  «Мы **не переписываем транзакционное ядро АБС** (CFT-Bank), что действительно заняло бы 2 года. Мы используем стандартный микросервисный паттерн:
  - В структуре счетов создается новый атрибут `account_tier = COLD_VAULT`.
  - Логика изоляции реализуется на уровне **сервисной шины (API Gateway / Оркестратора)**: шина блокирует прямые вызовы к шлюзу СБП (Way4) для счетов с данным атрибутом и перенаправляет запрос во внешнюю стейт-машину 24-часового таймера.
  - Сама проводка в АБС исполняется через 24 часа как стандартный внутрибанковский мемориальный ордер между счетами одного клиента. Для АБС это типовая операция, не требующая изменения клирингового ядра».

Вопрос 11: В условиях кейса сказано, что данные о клиентах поступают с задержкой до суток. Как ваш конвейер уложится в 150 миллисекунд реального времени при неполных данных?

- **Эталонный ответ:**
  «Архитектура конвейера разделена на два контура:
  1. **Offline Batch Processing (Обогащение раз в сутки):** Медленные исторические агрегаты (среднемесячные обороты, скоринговые профили) пересчитываются ночью в Hadoop/DWH и загружаются в быстрый кэш Redis (Feature Store).
  2. **Online Streaming (Реальное время за 20 мс):** В моменте транзакции мы оцениваем сигналы, доступные мгновенно:
     - Параметры платежа (сумма, реквизит получателя);
     - Телеметрия устройства (Device ID, IP, геолокация);
     - Телеком-статус через мобильный SDK (Call State — идет ли звонок прямо сейчас);
     - Наличие процессов AnyDesk/RustDesk. CatBoost обучен работать в условиях пропусков части офлайн-фичей. При неполноте исторических данных алгоритм не блокирует операцию, а переводит ее в серая зону и запрашивает 15-секундный Liveness Step-Up».

Вопрос 12: За счет чего вы уложитесь ровно в 6 месяцев до промышленного Go-Live?

- **Эталонный ответ:**
  «Срок в 6 месяцев декомпозирован на **12 двухнедельных Agile-спринтов** с применением параллельных треков:
  - Трек мобильной разработки (Liveness SDK) и трек Core Banking стартуют параллельно с Месяца 2.
  - Мы не разрабатываем нейросеть детекции лиц с нуля — мы адаптируем готовые открытые архитектуры (FaceNet / MobileNetV3) под On-Device инференс TFLite и Metal.
  - Регрессионное тестирование и аудит ИБ (по Положению ЦБ № 683-П) проводятся параллельно в Месяцы 4–6.
  - Заключительный 6-й месяц отведен под закрытый пилот на 50 000 сотрудников и лояльных клиентов банка для финальной калибровки порогов False Positives перед раскаткой на 30 млн человек».